

1차 문서보안용

1. 문서 정보 / Document Information

- **문서명(KR):** AI 기반 전자문서·프롬프트 보안 작성 가이드라인
- **문서명(EN):** AI-Based Secure Content & Prompt Authoring Guidelines
- **적용 범위:** 메일 / 메신저 / 코드 / 고객 응대 / 데이터 요청 / 프롬프트 등 모든 비정형 텍스트
- **보안 등급:** Internal Use Only (사내 배포 전용 / 외부 반출 금지)

2. 일반 원칙 / General Policy Principles

- **(KR)** 모든 전자문서 및 프롬프트는 정보 자산으로 간주되며, 작성 및 전송 시 기밀성과 무결성이 반드시 보장되어야 한다.
- **(EN)** All digital content and AI prompts are treated as information assets and must maintain confidentiality and integrity during authoring and transmission.
- **(KR)** 민감정보 및 인증 정보는 원문 상태로 직접 포함하거나 외부 시스템으로 전송하여서는 안 된다.
- **(EN)** Sensitive or credential data must not be directly embedded or transmitted in raw form to external systems.

3. 민감 정보(PII/Secrets) 포함 금지 항목

구분	예시(KR)	Example (EN)
개인식별정보	주민등록번호, 여권번호	SSN, Passport Number
인증 정보	API Key (sk-...), OAuth Secret	API Keys, Access Tokens
금융 정보	계좌번호, 카드번호	Bank Account, Credit Card
내부 기밀명	미공개 프로젝트명, 계약 단가	Confidential project name

- **(KR)** 상기 정보가 포함될 가능성이 있는 경우, 즉시 마스킹 또는 대체 처리를 수행하여야 한다.
- **(EN)** If any of the above may appear, immediate masking or substitution is required before usage.

4. 보안 위반 사례 / Examples of Prohibited Usage

- **(KR)** "김과장님, 고객 홍길동 주민번호 900101-1234567은 꼭 보안 유지 부탁드립니다"
 - **(EN)** "Manager Kim, customer Hong Gil-dong's RRN 900101-1234567 must be kept confidential." → ❌ 금지
 - **(KR)** API Key를 코드 또는 채팅에 직접 기입하는 행위
 - **(EN)** Hardcoding API Keys into code or AI prompts → ❌ BLOCK IMMEDIATELY
-

5. 보안 준수 예시 / Compliant Examples

-  "고객의 고유 식별번호는 내부 보안 정책에 따라 별도 암호화 처리되었습니다."
 -  "The customer's identifier has been masked according to internal compliance policy."
 -  API Key 직접 삽입 → "<KEY_REDIRECT_TOKEN>" 형태로 교체 후 KeyVault에 저장
-

6. AI 활용 시 보안 지침 / AI-Specific Secure Authoring Rules

- **(KR)** AI 모델 호출 시 민감정보 원문을 프롬프트에 포함하지 않는다.
 - **(EN)** AI prompt must never include raw PII or confidential data.
 - **(KR)** RAG를 통해 내부 문서를 인용하는 경우, 문서 보안 등급을 검증하고 조회 범위를 최소화한다.
 - **(EN)** When leveraging RAG, ensure proper access level and minimal document exposure.
-

7. 감시/모니터링 정책

- **(KR)** 시스템은 모든 입력 텍스트를 실시간 점검하며, 보안 위반 판단 시 전송 차단 또는 수정 권고를 수행한다.
- **(EN)** The system monitors all input in real-time to block or suggest correction for any policy violations before transmission.